

Boxed: A Sovereign, Polyglot Sandbox Substrate for Autonomous Code-Generating Agents

Akshay Kumar
Independent Researcher
United States
akumar8@mt.iitr.ac.in

Abstract—Autonomous large language model (LLM) agents increasingly write, execute, and iterate on code inside their reasoning loop, which makes the sandbox—not the model—the hot path of an agent task. Operators today choose among three unsatisfying options: roll-your-own Docker, which is fast to prototype but routinely ships without seccomp profiles, egress filtering, read-only root filesystems, or process caps; proprietary SaaS sandboxes, which are hardened but vendor-locked and incompatible with bring-your-own-key (BYOK) or data-sovereignty requirements; and research virtual machine monitors, which provide the right isolation primitives but target a boot-once serverless invocation model rather than the agent’s create/execute/destroy cycle. We present Boxed, an open-source sandbox substrate co-designed for agentic code execution. Boxed contributes a deliberately narrow four-method Go driver interface that makes the isolation backend a deployment-time choice; a 1.32 MiB stripped Rust in-sandbox agent that streams stdout, stderr, and on-disk artifacts over JSON-RPC 2.0 as they are produced; and a stateless BYOK control plane that any operator can self-host. The current release ships a production-ready Docker driver with stubbed Firecracker and WebAssembly backends. On a contended developer laptop, Boxed sustains a median end-to-end create+exec+destroy latency of 303 ms (p95 395 ms, p99 495 ms) over 200 sequential sandboxes, peaks at 9.8 sandboxes/s at concurrency 8, and holds 0.4 MiB median idle resident-set size per sandbox. A twelve-vector behavioural escape probe classifies 5 of 12 attempts as denied; we publish the full per-vector result table, attribute each undenied vector to a specific configuration gap in the current Docker driver, and identify which verdicts are artifacts of signature-based classification rather than demonstrated policy failures. An end-to-end LLM-driven code-generation trace over 20 HumanEval-style tasks passes 100% at median 30.32 s wall-clock, of which 17% is model inference. Boxed is MIT-licensed at <https://github.com/akshayaggarwal99/boxed>.

Index Terms—sandboxing, code execution isolation, large language models, autonomous agents, containers, microVMs, WebAssembly, bring-your-own-key, data sovereignty, JSON-RPC

I. Introduction

The 2024–2026 wave of autonomous code-generating agents—from SWE-agent [1] and AutoGPT-style harnesses through commercial products such as Cursor, Devin, and Claude Code—has changed what “running untrusted code” means in practice. A modern agent emits dozens of short-lived programs per task: it generates a snippet, executes it, inspects stdout, reads back a generated file, and iterates. Unlike batch compilation or single-

shot execution, the sandbox is not a post-hoc verification step but a component of the agent’s decision loop. The hot path of the agent is the sandbox, not the model.

Today’s options for hosting that hot path fall into three buckets, each unsatisfying for an operator who cares about cost, latency, and data sovereignty simultaneously.

Roll-your-own Docker is the modal choice. It is fast to prototype but routinely shipped without seccomp profiles, network egress filters, read-only root filesystems, or process and memory caps, leaving the host one `rm -rf /` away from compromise [2].

Proprietary SaaS sandboxes—E2B [3], Modal Sandbox [4], Cloudflare Sandbox [5]—ship hardened isolation but require the operator to transmit every byte of generated code, execution output, and intermediate artifact to a third party, with no BYOK or self-host story for regulated workloads in healthcare, finance, or government.

Research VMMs such as Firecracker [6] provide the right primitives but are designed for AWS Lambda’s invocation model—boot once, run an event loop, amortize startup across many requests—rather than the agent’s create/execute/destroy cycle, and they ship without an in-guest agent that can stream artifacts back to the caller.

We argue that agentic workloads deserve a sandbox substrate that treats the LLM client as a first-class citizen: pluggable isolation backends so one control plane drives Docker on a laptop and Firecracker in production, an in-sandbox agent that streams standard output and on-disk artifacts as they appear, and a sovereign deployment story in which the operator owns the control plane, the keys, and the data.

A. Contributions

- A narrow driver interface (Section IV) that abstracts container runtimes, microVMs, and Wasm sandboxes behind four Go methods, making the isolation backend a deployment-time configuration choice rather than a compile-time dependency. The current release ships a Docker driver and stubs for Firecracker and Wasm.
- A Rust in-sandbox agent that streams stdout/stderr chunks as discrete JSON-RPC events rather than buffering until process exit, and mirrors files written

under a watched directory back to the caller as structured artifact events.

- A BYOK control plane (Section V) that any operator can self-host with a key of their choosing, deliberately foreclosing a third-party multi-tenant deployment of Boxed in exchange for removing the vendor from the trust boundary.
- An open benchmark harness (Section VI) reporting cold-start latency, throughput under concurrency, per-sandbox idle overhead, a twelve-vector adversarial escape probe with full per-vector results, and an end-to-end LLM-driven code-generation trace. Raw CSV traces ship with the source.
- A negative-results disclosure: we publish the seven escape vectors our current configuration fails to deny, map each to the specific line of driver configuration responsible (Section VII), and separate genuine policy gaps from artifacts of our classification method.

On a MacBook Pro (Apple M1 Pro, 16 GB, Docker Desktop) running typical background processes, Boxed achieves a median end-to-end create+exec+destroy latency of 303 ms (p95 395 ms), single-trial peak throughput 9.8 sandboxes/s, and 0.4 MiB median per-sandbox idle working set as reported by docker stats. We also report what does not work: a behavioural probe of 12 adversarial attempts classified 5 as denied, surfacing concrete hardening gaps in the current Docker driver—writable rootfs, the default Linux capability set, no PidsLimit, and a permissive ptrace policy—which we discuss in Section VII and close in the planned Firecracker driver.

II. Background and Related Work

A. Container-based isolation

Linux containers built on namespaces, cgroups, and seccomp underpin nearly every modern development sandbox. They are cheap to start—roughly 50–200 ms when images are warm—which is why they dominate workloads that create and destroy execution environments frequently. That speed comes at a security cost: containers share the host kernel, exposing a substantially larger attack surface than hardware-isolated alternatives. The consequence is not merely theoretical. CVE-2019-5736 [2] is the canonical reminder that a single bug in runc can turn a container into a host. Hardened container runtimes such as gVisor [7] interpose a userspace kernel between the workload and the host, shrinking the trusted computing base at the cost of a 2–5 $\times$ syscall overhead. For an agent executing hundreds of short-lived programs per task, that multiplicative cost must be weighed against the reduced risk of kernel-level compromise.

B. Lightweight virtual machines

Firecracker [6] demonstrated that a stripped-down KVM VMM can boot a guest kernel in ~ 125 ms with < 5 MiB of memory overhead per VM, and now powers AWS Lambda. Kata Containers [8] and Manco et al.’s My

VM is Lighter (and Safer) than Your Container [9] pursue the same hypervisor-as-isolation thesis from complementary angles. These systems optimize boot cost and steady-state memory overhead under a serverless assumption: boot once, run an event loop, amortize startup across many invocations. That assumption diverges from the access pattern of an autonomous coding agent, which creates an ephemeral sandbox, runs one short-lived program, extracts outputs, and destroys the environment—hundreds of times per task. It is the cumulative lifecycle cost, not cold-start latency in isolation, that determines whether a substrate is viable for agentic workloads, and the lightweight-VM literature offers comparatively little guidance on that regime.

C. Unikernels and WebAssembly

Unikernels [10] push isolation further by compiling the application together with a library operating system into a single boot image, eliminating the general-purpose kernel layer and minimizing the trusted computing base—at the cost of requiring application-specific compilation, which precludes executing arbitrary dynamically generated binaries. WebAssembly and WASI [11] reframe the problem at the language level: the guest is portable bytecode with explicit capability-based imports, and the “sandbox” is a runtime embedded in the host process. Microsecond-scale instantiation is exactly what a create-heavy agent workload wants. The obstacle is workload compatibility: agents emit unmodified Python scripts, shell commands, and native binaries that assume a POSIX environment with filesystem access, process spawning, and dynamic linking. Until the WASI toolchain supports unmodified language runtimes and arbitrary native executables, Wasm remains promising but impractical as a general-purpose agent sandbox.

D. Agent-oriented sandbox platforms

A recent generation of products targets LLM agents specifically. E2B [3] runs Firecracker microVMs behind a SaaS API and reports ~ 150 ms cold start; Modal Sandbox [4] layers gVisor over Firecracker for defence in depth; Daytona [12] ships an AGPL Docker-backed self-hosted development environment; Cloudflare Sandbox [5] reuses V8 isolates for ~ 5 ms cold start at the cost of restricting execution to JavaScript and Wasm. Cold-start figures for these platforms are vendor claims measured under undisclosed conditions and are not directly comparable to our end-to-end lifecycle measurement; we reproduce them in Table I as reported, not as validated. Two limitations are shared across the category. First, none exposes a pluggable isolation backend: the choice of Docker, Firecracker, or V8 is fixed at the platform level and cannot be re-targeted from a laptop to a production cluster without migrating systems. Second, with the exception of Daytona, all operate exclusively as hosted services, which is incompatible with BYOK deployment and raises

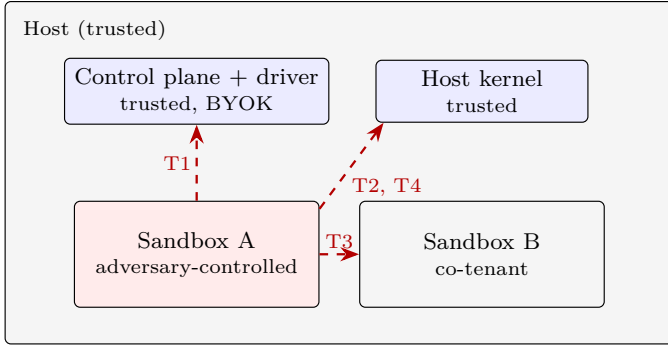


Fig. 1. Trust boundary. Adversary-controlled code executes inside a sandbox; the control plane, driver, and host kernel are trusted. Dashed arrows are the four threat classes the substrate must resist. Side channels between co-tenants on shared hardware are out of scope.

data-sovereignty concerns for regulated workloads. Table I positions Boxed within this landscape.

E. Evaluating LLM-generated code execution

HumanEval [13] established single-function code generation as a standard benchmark, measuring whether a model can synthesize a correct implementation from a natural-language specification. SWE-agent [1] extended this to agent-mediated software engineering, where the agent must run the code it writes and refine it, not merely emit it. Our agent-trace evaluation (Section VI) follows the latter regime: the model emits a candidate Python function, Boxed executes it alongside a self-checking assertion, and the harness records pass or fail. By decomposing end-to-end wall-clock into model inference versus sandbox lifecycle, we quantify the part of agent latency that a substrate can actually influence.

III. Threat Model

We assume an adversary with full control over the code submitted to a sandbox: they may craft arbitrary Linux binaries, issue any syscall sequence, and attempt network egress to any destination. The adversary does not control the control plane, the driver implementation, or the host kernel; these remain trusted. Fig. 1 shows the resulting trust boundary.

We aim to prevent four classes of attack.

T1 — Host filesystem access. Read or write access to the host filesystem outside the sandbox’s ephemeral root, whether through path manipulation, symbolic links, or direct mount operations.

T2 — Namespace escalation. Escape from the allocated network or process namespace into the host’s network stack or process tree, which would let the adversary observe or manipulate unrelated system activity.

T3 — Co-tenant exfiltration. Access to credentials, artifacts, or data belonging to a concurrent sandbox on the same host.

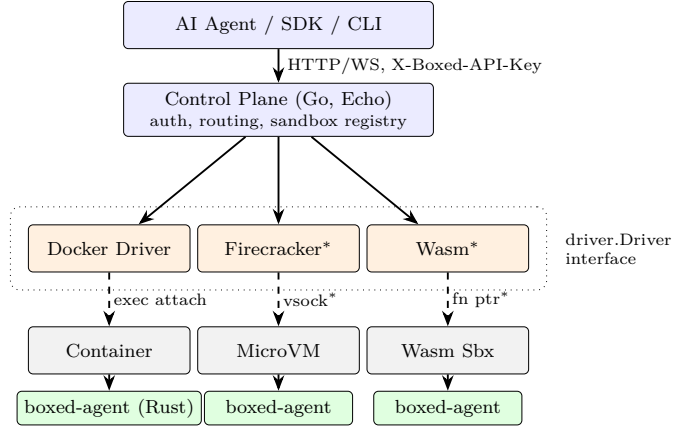


Fig. 2. Boxed architecture. The control plane drives a single narrow Driver interface, behind which the Docker driver ships today and Firecracker/Wasm drivers are stubbed. A common Rust agent runs inside every sandbox and speaks JSON-RPC over whatever byte stream the driver supplies. *Stubbed; not production-ready in the current release.

T4 — Resource exhaustion. Denial of service against the host through fork bombs, memory exhaustion, or other unbounded resource consumption.

Side-channel attacks exploiting shared hardware—cache timing, speculative execution—are explicitly out of scope. Mitigating them requires per-customer hardware partitioning, a deployment decision that belongs to the operator rather than a property the substrate can enforce.

IV. Design

Boxed is structured around three components and one narrow interface (Fig. 2): a stateless control plane, a pluggable driver layer, and an in-sandbox agent. The design decouples orchestration from the isolation mechanism so that the same control plane drives Docker containers on a development laptop and Firecracker microVMs in production without modification.

A. Driver Interface

The central abstraction is a single Go interface whose sandbox-lifecycle subset is deliberately narrow, so that future drivers—Firecracker, Wasm, Kata—can be added without touching the control plane. The full interface also exposes file-injection and listing helpers used by the SDK, but four lifecycle methods constitute the minimal contract every backend must satisfy:

```
type Driver interface {
    Create(ctx context.Context,
        cfg SandboxConfig) (string, error)
    Start(ctx context.Context, id string) error
    Stop(ctx context.Context, id string) error
    Connect(ctx context.Context,
        id string) (io.ReadWriteCloser, error)
}
```

Create instantiates a sandbox from the supplied configuration and returns an identifier; Start and Stop bound its lifetime; Connect returns a raw byte stream over which the

TABLE I

Agent-oriented sandbox runtimes (data as of 2026-05). Cold-start figures for systems other than Boxed are vendor claims measured under undisclosed conditions and are reproduced as reported, not validated by us; the Boxed figure is the end-to-end create+exec+destroy median of Section VI.

System	Isolation	Cold start	Pluggable drivers	BYOK / self-host	License	First-class artifacts
Boxed (this work)	Docker → FC* / Wasm*	303 ms (measured)	yes	yes	MIT	yes
E2B [3]	Firecracker	~150 ms (claim)	no	limited	Apache-2.0	yes
Modal Sandbox [4]	gVisor + Firecracker	~1.5 s (claim)	no	no	proprietary	yes
Daytona [12]	Docker	not reported	no	yes	AGPL	no
Cloudflare Sandbox [5]	V8 isolates	~5 ms (claim)	limited	no	proprietary	limited

*Stubbed; Docker is the only production-ready driver in the current Boxed release.

control plane talks to the in-sandbox agent. For the Docker driver that stream is a Docker exec attach; for the planned Firecracker driver it will be a vsock connection; for a future Wasm driver it will be a host-side function pointer. The control plane is agnostic to which case it is servicing, which is what makes backend selection a deployment-time rather than a compile-time decision.

B. Control Plane

The control plane is a stateless HTTP and WebSocket server built on the Echo framework that maps POST /v1/sandbox requests through the configured driver. Two choices matter for agent workloads.

First, create returns once the underlying runtime reports that the sandbox process has launched—for the Docker driver, once ContainerStart acknowledges—with status: ready. The caller does not poll a separate status endpoint. The first exec after create absorbs the small additional cost of waiting for the agent’s JSON-RPC loop to come up. Because an agent task may create dozens of short-lived sandboxes, removing a polling round-trip from each one is a material saving in the aggregate.

Second, authentication uses a bring-your-own-key header (X-Boxed-API-Key). The operator supplies the key at startup; Boxed never issues, rotates, or stores keys. This deliberately forecloses a third-party multi-tenant deployment of Boxed, in exchange for letting any operator self-host without extending trust to a vendor. For organizations under data-sovereignty constraints, all generated code, execution output, and intermediate files stay inside the operator’s infrastructure boundary.

C. In-Sandbox Agent

Inside every sandbox runs boxed-agent, a single statically linked Rust binary built on tokio, serde, and notify (1.32 MiB stripped). It speaks JSON-RPC 2.0 framed as newline-delimited JSON over the driver-supplied byte stream.

On exec, the agent spawns the user’s command as a child process and streams stdout and stderr chunks back as discrete RPC events as they appear, rather than buffering until exit. This streaming discipline matters for agent workloads in which the model must react to partial output or an early error signal without waiting for the program

to finish. In parallel, an inotify-based watcher monitors the artifact directory (/output); any file written there is emitted as an artifact event carrying the file’s MIME type and base64-encoded contents. An agent that asks Python to write plot.png therefore receives the bytes as an unsolicited event, with no second round-trip and no polling.

D. Artifact Protocol

Treating files as first-class outputs is what makes the substrate practical for workloads where the model expects the side effects of code, not only its console output. Fig. 3 shows where artifact events sit in the sandbox lifecycle.

The current release implements inline streaming: the watcher reads the file, guesses its MIME type, base64-encodes it, and emits it on the same channel that carries stdout and stderr. A size cap of 10 MiB bounds the memory and serialization cost of inlining; files above the cap are currently skipped with a logged warning rather than delivered. The wire protocol reserves a url field on the artifact event for an out-of-band upload path—in which the agent would PUT the file to a pre-signed URL and return only a reference—but that path is not implemented in this release. We flag this explicitly because a substrate that silently drops large artifacts is a correctness hazard for any workload that emits model checkpoints or datasets; closing this gap is scheduled ahead of the Firecracker driver.

Because both the artifact protocol and the agent live above the driver interface, artifact semantics are invariant across backends: the Docker driver today and the Firecracker and Wasm drivers later expose identical behaviour to the caller.

V. Implementation

The current release comprises 2,374 lines of Go in cmd and internal (control plane, Docker driver, CLI) and 870 lines of Rust for the in-sandbox agent. The control-plane binary is 12.0 MiB and the agent binary 1.32 MiB stripped. Three implementation details are worth stating precisely, because two of them differ from what a reader might assume.

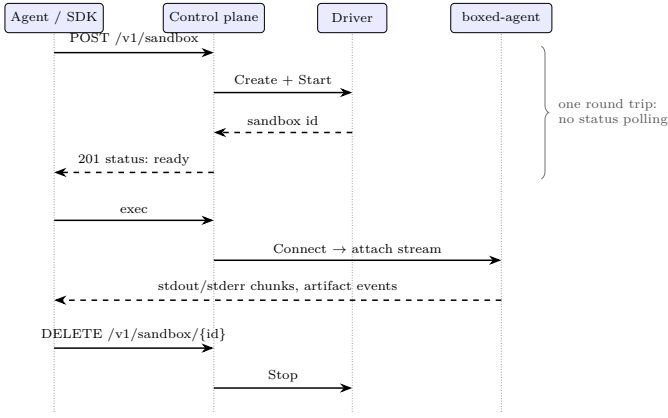


Fig. 3. Sandbox lifecycle. create returns as soon as the runtime reports the sandbox process launched, so the client never polls a status endpoint; the first exec absorbs agent start-up. Output and artifacts stream back on one channel as they are produced.

A. Agent injection and container lifecycle

The Docker driver bind-mounts the host’s boxed-agent binary into the container read-only at create time, so a stock base image (python:3.10-slim) can be reused across sandboxes with no Boxed-specific image registry to maintain. Two tmpfs mounts back /tmp and the /output artifact directory, so both are ephemeral and never touch the host filesystem.

The container’s own PID 1 is a tail -f /dev/null placeholder whose only job is to keep the namespace alive; boxed-agent is launched separately by Connect as a Docker exec whose attached stream carries JSON-RPC. We state this explicitly because the distinction has security consequences: the agent is a child of the container’s init rather than init itself, so a workload sharing the sandbox’s PID namespace can see it, which is one reason the permissive ptrace default discussed in Section VI matters. Under the planned Firecracker driver the agent does become the guest init, communicating over vsock; the interface in Section IV-A is what allows that change without disturbing the control plane.

B. Single-round creation

POST /v1/sandbox returns once the runtime has launched the sandbox process rather than requiring the caller to poll a status endpoint (Fig. 3). The first exec after create absorbs the latency of the agent’s JSON-RPC loop initializing. The client therefore observes a simple request–response model, and per-sandbox polling load disappears from the control plane—which matters precisely because agent tasks create sandboxes in bulk.

C. Resource and network model

Every sandbox is created with a CPU quota (NanoCPUs) and a memory cgroup, defaulting to 1.0 core and 512MiB and validated against ceilings of 4.0 cores and 8GiB. A TTL goroutine stops the sandbox when its

timeout expires. Notably absent is any PidsLimit, which Section VI shows is exploitable.

The driver exposes a binary network choice via EnableNetworking: when false the container is attached to Docker’s none network, leaving only loopback; when true it joins the default bridge with full host-bridged egress. The driver.NetworkPolicy type already accepts an egress allow-list, but enforcement of fine-grained rules—per-sandbox iptables chains on the container’s veth, for example—is roadmap, not implemented. This has a direct consequence for the escape evaluation: egress attempts to RFC1918 and link-local metadata addresses are plausibly interdicted by Docker Desktop’s NAT topology rather than by any Boxed policy, and we score them accordingly in Section VI.

VI. Evaluation

We evaluate Boxed along five axes: cold-start latency, throughput under concurrency, idle per-sandbox overhead, adversarial escape resistance, and end-to-end LLM-agent task latency. The harness and raw CSV traces are open-source alongside the paper.

A. Setup

All measurements were taken on a MacBook Pro with an Apple M1 Pro SoC and 16 GB of unified memory running macOS, using Docker Desktop with the arm64 python:3.10-slim image pre-pulled to keep image-pull latency out of the measured path. Cold-start, throughput, and overhead numbers were collected on a freshly restarted Docker engine. The agent-trace experiment was deliberately run after the three load-generating phases, to characterize behaviour under the accumulated state of a Docker Desktop hypervisor that has been under sustained pressure. Unless otherwise noted each create+exec+destroy cycle runs a synthetic print(‘ok’) workload, which isolates substrate overhead from application computation. Only the Docker driver is exercised; Firecracker and Wasm remain stubs.

B. Cold-Start Latency

We measure end-to-end create+exec+destroy time for 200 sequential sandboxes on a warm engine (Fig. 4). The median is 303ms with a tight interquartile band (IQR 28ms) and a heavy upper tail (p95 395ms, p99 495ms). The create phase alone has a median of 165ms, making it the dominant contributor. The bulk of that is container-instantiation cost inside the Docker driver; the agent adds single-digit milliseconds between create returning and the first exec acknowledgement. This is a single benchmark run on a single host; we release the harness so that replication across hardware and operating systems is possible, and treat that replication as future work rather than a claim we have discharged.

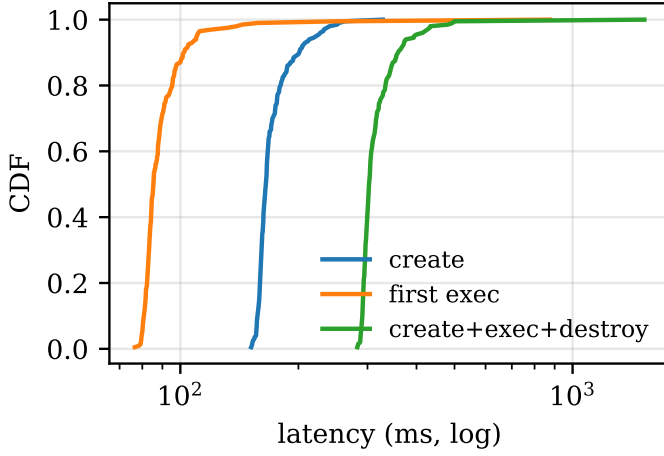


Fig. 4. CDF of create, first-exec, and total latency over 200 sequential sandboxes.

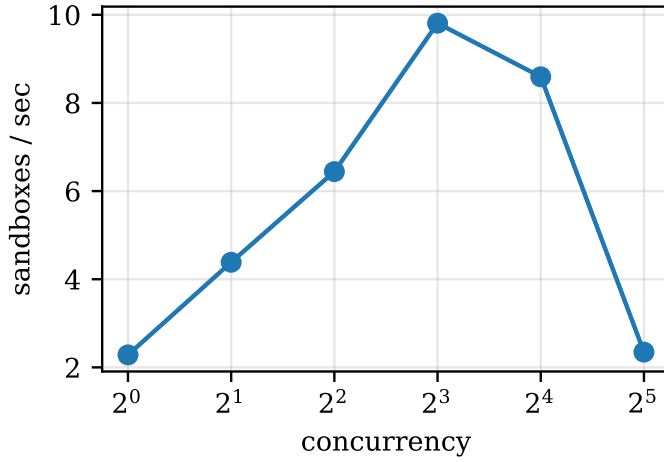


Fig. 5. Sustained sandbox-creation rate as a function of client concurrency.

C. Throughput Under Concurrency

We sweep client concurrency $c \in \{1, 2, 4, 8, 16, 32\}$, driving 80 sandbox lifecycles at each level, and report sustained sandboxes per second (Fig. 5, Table II). Throughput rises monotonically to 9.8 sandboxes/s at $c=8$, dips slightly at $c=16$, and collapses to 2.35 sandboxes/s at $c=32$, where elapsed time for the same 80 lifecycles grows roughly $4\times$. No errors occurred at any level. We read the $c=16$ dip as host-noise variance rather than a structural feature and do not over-interpret the curve shape; the $c=32$ collapse is large enough to be a real contention effect in Docker Desktop’s LinuxKit VM, which multiplexes every container operation through a single virtualized kernel. Section VII discusses why we expect a native Linux/Firecracker deployment to lift this ceiling.

D. Per-Sandbox Idle Overhead

We sample each idle sandbox’s resident-set size and CPU five seconds after create returns (Fig. 6). Median

TABLE II
Throughput sweep. 80 sandbox lifecycles per concurrency level, single trial each, zero errors throughout.

Concurrency c	Completed	Elapsed (s)	Sandboxes/s
1	80	35.04	2.28
2	80	18.24	4.39
4	80	12.42	6.44
8	80	8.16	9.81
16	80	9.31	8.59
32	80	34.11	2.35

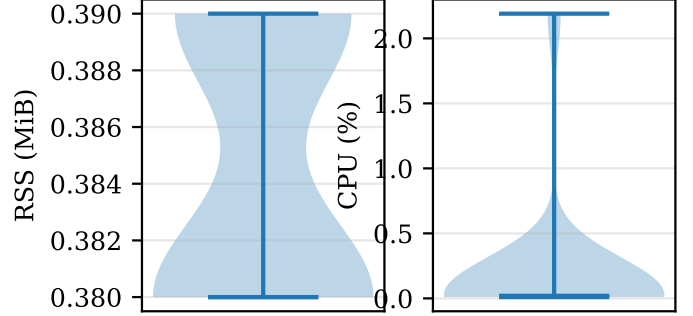


Fig. 6. Idle resident-set size and CPU per sandbox.

RSS, as reported by docker stats via the container cgroup working set, is 0.4 MiB; median CPU is 0.02%.

Two caveats apply. On macOS, Docker Desktop runs containers inside a LinuxKit VM, so the working-set figure reflects accounting inside that VM rather than a process-level measurement on a native Linux host, and may under-report. We therefore treat the absolute number as a relative ordering rather than ground truth and plan re-measurement on Linux. That said, the order of magnitude is consistent with the design: the agent is a stripped Rust binary that holds no buffers, opens no files at startup, and parks on a single tokio event loop awaiting a JSON-RPC frame—in contrast to a Python- or Node-based agent carrying an interpreter, module cache, and garbage-collector metadata even when idle. Across the dozens of concurrent sandboxes an agent operator may run, that difference compounds.

E. Behavioural Escape Probe

We exercise the sandbox with twelve attempts drawn from common container-escape patterns [2]: privileged mount, `/proc/1/root` traversal, Docker socket access, kernel module loading, raw-socket binding, namespace escape via `unshare`, egress to RFC1918, egress to link-local metadata (169.254.169.254), a fork bomb, a 4 GiB memory bomb, a write to `/etc`, and `ptrace` of a non-self process. Each attempt runs in a fresh sandbox and is classified by matching captured stdout/stderr against a list of denial signatures. Table III gives the full per-vector result.

This is a behavioural probe, not a formal isolation proof, and we are careful about what the numbers license. The classifier cannot distinguish an attempt denied by Boxed

TABLE III

Behavioural escape probe: all twelve vectors, mapped to the threat classes of Section III. 5/12 (42%) denied. “Locus” records where the denial or failure plausibly originates; entries marked † are classifier artifacts discussed in the text, not demonstrated boundary crossings.

Vector	Threat	Verdict	Locus / gap exposed
mount_host	T1,T2	denied	no CAP_SYS_ADMIN
modprobe	T2	denied	no CAP_SYS_MODULE
setns	T2	denied	namespace caps absent
rfc1918	T3	denied	Docker NAT, not Boxed policy
imds	T3	denied	Docker NAT, not Boxed policy
ro_root	T1	undenied	ReadonlyRootfs unset
raw_socket	T2	undenied	CapDrop: ALL disabled
ptrace_host	T2,T3	undenied	seccomp permits ptrace
fork_bomb	T4	undenied	no PidsLimit cgroup
mem_bomb	T4	undenied	† signature not emitted
proc1_root	T1	undenied	† in-sandbox root only
docker_sock	T2,T3	undenied	† socket not mounted

policy from one denied incidentally by the Docker bridge or kernel defaults: the RFC1918 and metadata-endpoint denials are plausibly the work of Docker Desktop’s NAT topology rather than any enforcement of ours, and we record them as such in Table III. With that caveat, the suite classifies 5 of 12 attempts (42%) as denied.

Four of the seven undenied vectors correspond to real, locatable configuration gaps in the current Docker driver, each verifiable by reading the source: (i) the container rootfs is writable because ReadonlyRootfs is never set, so the write to /etc lands; (ii) the CapDrop: ALL block is commented out, so the container retains Docker’s default capability set including CAP_NET_RAW, and the raw-socket bind succeeds; (iii) no PidsLimit cgroup is configured, so the fork bomb is bounded only by whatever the host scheduler tolerates, even though a memory cgroup is enforced; and (iv) the default seccomp profile permits ptrace within the sandbox PID namespace, which is a sharper concern here than it would be otherwise because Section V establishes that boxed-agent is a peer process in that namespace rather than its init.

The remaining three undenied verdicts are, on inspection, artifacts of signature-based classification rather than evidence of a failed boundary, and we mark them † rather than quietly counting them as successes for the adversary. The memory bomb requests a 4 GiB allocation against a 512 MiB cgroup; a process terminated by SIGKILL emits no message, so no denial signature appears in captured output even when the cgroup binds exactly as intended. /proc/1/root resolves to the root of the container’s own init inside the sandbox PID namespace, not the host’s, so listing it succeeds without crossing any boundary. And the Docker socket is simply not among the mounts the driver configures, so the probe observes an absent path. In each case the honest reading is that our classifier is too weak to adjudicate the vector, not that the sandbox failed. Replacing signature matching with post-condition verification against host state—did the file actually appear

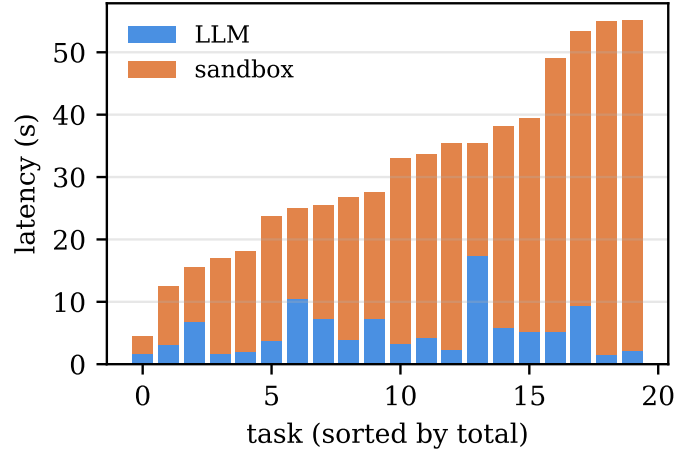


Fig. 7. Per-task LLM time versus sandbox time over 20 HumanEval-style code-generation tasks.

outside the mount namespace? did the process count actually exceed the cap?—would remove this ambiguity and is the natural next iteration of the suite.

We report the aggregate as 5/12 rather than adjusting it upward for the three artifacts, because the classifier is what we actually ran and re-scoring after the fact on the basis of a plausible reading would be exactly the kind of favourable post-hoc adjustment that makes security evaluations untrustworthy. None of the twelve attempts produced a host escape in our tests. But each genuine gap thins the defence chain an operator would reasonably expect, which is why we treat them as bugs against this release rather than as design limitations.

F. End-to-End Agent Trace

We drive Boxed with a Gemini-based code-generation loop over 20 HumanEval-style tasks [13]: for each task the model emits a candidate Python function, Boxed executes it together with a self-checking assertion, and the harness records pass/fail. All 20 tasks pass (Fig. 7). Median end-to-end wall-clock is 30.32 s, of which 17% is model inference and the remainder is dominated by sandbox creation.

The striking number is the create phase: under sustained load it degraded to a median of 15.32 s, roughly two orders of magnitude above the 165 ms median measured on a freshly warmed engine. Because this phase is the same code path in both experiments and the only variable is the accumulated state of Docker Desktop’s LinuxKit VM after three prior load-generating phases, we attribute the degradation to hypervisor contention rather than to the Boxed runtime—but we note it is an attribution supported by the experimental ordering, not by a controlled comparison, and a Linux replication would settle it. Either way the gap motivates both native Linux with Firecracker as a deployment target and pool-based reuse as control-plane work (Section VII).

TABLE IV
Hardening checklist for the current Docker driver.

Gap	Vector	Remediation
Writable rootfs	ro_root	set ReadOnlyRootfs
Default capability set	raw_socket	CapDrop: ALL + allow-list
No process cap	fork_bomb	set PidsLimit
Permissive ptrace	ptrace_host	custom seccomp profile
No egress enforcement	—	per-sandbox iptables
Oversize artifacts dropped	—	implement upload path

G. Threats to Validity

All measurements were taken on a single MacBook Pro (M1 Pro, 16 GB) running typical background processes—browser, IDE, chat clients—rather than a quiesced benchmark host. We did not pin Boxed’s processes to dedicated cores, isolate Docker Desktop’s LinuxKit VM, or otherwise insulate the workload from incidental host activity. The heavy upper tail of the cold-start distribution (p99 495 ms versus median 303 ms) and the dip at $c=16$ are both consistent with sporadic host CPU contention rather than steady-state behaviour of Boxed.

Reporting median and IQR partially insulates central tendency from that contention, but the absolute numbers should be read as upper bounds on a contended developer environment, not as clean-room results. The throughput sweep is a single trial per concurrency level, which precludes any variance estimate or confidence interval. The escape probe is a behavioural signature matcher whose limits we quantify in Section VI-E. The comparison figures in Table I for other systems are vendor claims we did not reproduce. We release the full harness, including every caveat above, so that independent re-runs on quiesced Linux hosts can refine the picture.

VII. Discussion

A. Hardening checklist for the current driver

The Docker driver is the only production-ready backend in this release, and its default posture is weaker than it should be. Table IV states each gap, the vector it exposed in Section VI-E, and the remediation. Every item is a one-line configuration change in the driver’s HostConfig; none requires design work. We classify them as correctness bugs against this release, scoped for the next minor version, and enforced by default in the planned Firecracker driver. Operators running the current release on untrusted input should apply the right-hand column themselves.

B. Docker Desktop on macOS is a hypervisor

Our harness ran on Apple M1 Pro under Docker Desktop, which is itself a Linux VM. The cold-start numbers are fast in absolute terms but include the cost of round-tripping through the Docker socket inside that VM, and the throughput collapse at $c=32$ reflects contention for CPU and I/O inside a fixed-size LinuxKit VM that must multiplex every container operation through one virtualized kernel. We expect a native Linux deployment with a

Firecracker driver to reduce create latency substantially and to raise the concurrency ceiling, because sandbox creation would distribute across the full physical core count without the hypervisor hop. We state this as an expectation, not a result: we have not measured it, and the Firecracker driver is a stub.

C. Pool-based sandbox reuse

The control plane maintains a logical sandbox pool, but the Docker driver creates a fresh container per request. That choice buys a known-clean starting state—no residual filesystem or process state from a prior execution—at the cost of paying 165 ms of container instantiation on every call, which Section VI identifies as the dominant term in the 303 ms median.

Reusing a warmed sandbox for compatible follow-up requests would amortize that cost. Compatibility is naturally keyed on the tuple of base image, network policy, and resource limits; a reset between uses—killing descendant processes, clearing /tmp and /output, dropping injected files—is far cheaper than a full teardown and recreate. The roadmap has three parts: an LRU eviction policy bounding idle sandboxes, a compatibility-keyed lookup from SandboxConfig to pool entries, and a reset handshake the in-sandbox agent acknowledges over JSON-RPC. The driver interface already accommodates this: Create may return an existing identifier and Connect opens a fresh RPC channel to the same agent, so neither the SDK nor the client-facing API changes. For an agent workload that spawns dozens of sandboxes per task, this is the single highest-leverage optimization remaining.

D. Multi-host scheduling

Boxed today is single-host. A scheduler placing sandboxes across worker nodes—and accounting for NetworkPolicy at placement time so that co-located sandboxes cannot hold conflicting egress policies—is the natural next step for deployments whose aggregate concurrency exceeds one machine.

E. A Wasm driver, when the ecosystem allows

Wasm/WASI [11] is the most interesting future backend because of microsecond-scale instantiation and capability-based isolation enforced at the bytecode level, which would eliminate kernel boot and namespace setup from the create path entirely. The blocker is workload compatibility: agents emit Python scripts, shell commands, and native binaries that assume POSIX filesystem access, process spawning, and dynamic linking, none of which WASI transparently provides today. Adding the driver when the toolchain matures means implementing four methods and mapping Connect to an in-Wasm agent compiled for WASI; the control plane, artifact protocol, and SDK are unchanged. That is the payoff of keeping the interface narrow.

VIII. Conclusion

Boxed is a small, opinionated substrate for the increasingly common case of an LLM agent that creates, exercises, and destroys sandboxed execution environments hundreds of times per task. By keeping the driver interface narrow, the in-sandbox agent lean, and the deployment story BYOK and self-hostable, it offers operators an alternative to unsafe roll-your-own Docker on one side and vendor-locked SaaS on the other. On a hypervisor-backed laptop the substrate sustains 303 ms median cold start and 9.8 sandboxes/s peak throughput, and completes 100% of an end-to-end LLM code-generation trace.

We have also reported, in full and without adjustment, what the current release does not do: seven of twelve adversarial vectors go undenied, four of them because of specific configuration defaults we name and locate; oversize artifacts are silently dropped; egress policy is accepted but not enforced; and the strongest performance claims rest on single trials from a contended laptop. A substrate that asks operators to run untrusted code owes them that accounting more than it owes them a favourable number. The Firecracker and Wasm drivers, the hardening checklist in Table IV, and Linux replication of every measurement here are the next release.

Availability

The complete implementation—Go control plane, Rust in-sandbox agent, Docker driver, benchmark harness, raw CSV traces, and reproduction instructions—is available under the MIT license at <https://github.com/akshayaggarwal99/boxed>. Every performance number in this paper is generated from those traces by `bench/analyze/stats.py` and injected into the manuscript as a macro, so the text cannot drift from the data.

References

- [1] J. Yang, C. E. Jimenez, A. Wettig et al., “SWE-agent: Agent-computer interfaces enable automated software engineering,” in NeurIPS, 2024.
- [2] NIST NVD, “CVE-2019-5736: runc container breakout,” <https://nvd.nist.gov/vuln/detail/CVE-2019-5736>, 2019.
- [3] E2B, “E2B: Open-source secure sandboxes for AI agents,” <https://e2b.dev>, 2024.
- [4] Modal Labs, “Modal Sandbox documentation,” <https://modal.com/docs/guide/sandbox>, 2025.
- [5] Cloudflare, “Cloudflare Sandbox SDK,” <https://developers.cloudflare.com/workers/sandbox/>, 2025.
- [6] A. Agache, M. Brooker, A. Iordache, A. Liguori, R. Neugebauer, P. Piwonka, and D.-M. Popa, “Firecracker: Lightweight virtualization for serverless applications,” in USENIX NSDI, 2020.
- [7] Google, “gVisor: Container runtime sandbox,” <https://gvisor.dev>, 2018.
- [8] OpenInfra Foundation, “Kata Containers: Secure containers with the speed of containers,” in KubeCon, 2018.
- [9] F. Manco, C. Lupu, F. Schmidt, J. Mendes, S. Kuenzer, S. Sati, K. Yasukata, C. Raiciu, and F. Huici, “My VM is lighter (and safer) than your container,” in SOSP, 2017.
- [10] A. Madhavapeddy, R. Mortier, C. Rotsos, D. Scott et al., “Unikernels: Library operating systems for the cloud,” in ASP-LOS, 2013.
- [11] Bytecode Alliance, “WebAssembly system interface (WASI),” <https://wasi.dev>, 2024.

- [12] Daytona, “Daytona: Open-source dev-environment platform,” <https://daytona.io>, 2024.
- [13] M. Chen, J. Tworek, H. Jun et al., “Evaluating large language models trained on code,” arXiv preprint arXiv:2107.03374, 2021.